

# Lab 10 - Auditing and Remediation

## Intro

This week, we will take a look at basic auditing and remediation tools and concepts in order to detect and prevent machines from falling to the very vulnerabilities and misconfigurations that we have seen in the previous labs.

Since we have two sets of machines using the 192.168.1.0 network before you proceed

- Ensure the four boxes we used last week are **powered off** (mirai-cnc, mirai-loader, mirai-router, mirai-target-LAMP).

Check that seven boxes from early in the semester are **powered on** (freeBSD, pfSense, PFDesktop, ubuntu-webmin, ubuntuPing, win10, win10-privesc).

- You do not have admin access to freeBSD or pfSense. Ask a TA if you can't ping those boxes.

## Auditing Linux Logs

Earlier in the semester, in Lab 04, you ran an SSH brute force attack against one of your machines via a tool called hydra. Let's log onto that machine now (ubuntu\_webmin).

1. Repeat the steps performed in **Lab 05** as needed in order to gain a root shell on ubuntu\_webmin. You can move on to the next steps if you already have a root shell.
2. Run the following command to view logged SSH activity (If you get no entries when you run the command, it means you do not have root shell):  
`journalctl -u ssh`
3. Submit a screenshot of the SSH brute force you performed from Lab 04.

Clearly, there was nothing to stop a brute-force attack from occurring. Let's take some steps to determine how we might be able to fix that.

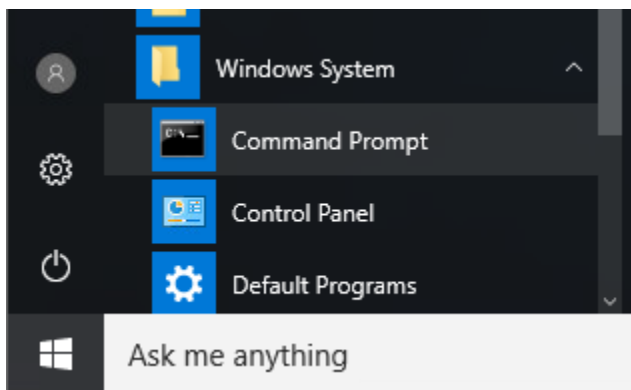
4. Browse through the `/etc/ssh/sshd_config` file, you'll notice that there are several settings that could be potentially configured.
5. Take a moment and list three potential services/options that could be configured to help mitigate brute-force attacks and why. We recommend you use Google and `man sshd_config` to research some of the options.

6. Explain **two additional** methods we can use to prevent brute force attacks. Be specific.

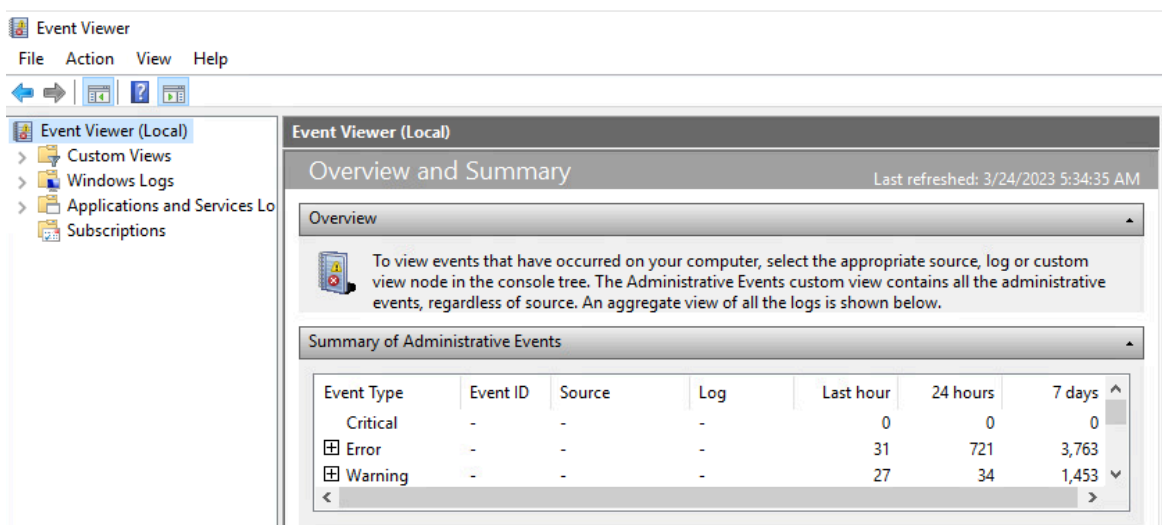
## Auditing Windows Logs

When securing a system, having verbose logs are useful for detecting failed and/or suspicious authentication attempts and when users or processes attempt unauthorized actions. This allows system administrators to detect exploited vulnerabilities and recreate attack situations for future patching and past incident reporting. We will use the Administrator accounts on some of the former boxes to audit and enable additional verbosity in the security logs (Windows Event Viewer) and apply group policies to prevent exploitation in the future (Group Policy Editor).

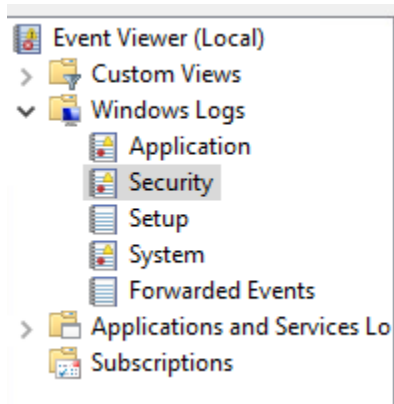
1. Log into the Windows10\_privesc (x.x.x.111) box with the local Administrator account “Grant” with the password you identified in Lab 06.
2. In the windows taskbar search for “Event Viewer” to open the Windows Event Viewer. Here we will be able to view all logs that have been collected based on the Windows Audit Policy settings.



The default page shown is the “Overview and Summary” page which helps show at a glance what kinds of logs have been collected in the recent past. The toolbar on the left-hand side can be used to browse by log type, while the toolbar to the right can be used to create custom views and filters to help zero in on the types of logs we are interested in.



3. We will start by looking for suspicious login entries in the Windows Event Viewer. Start by entering the “Security” log on the left-hand pane - this may take a while to load.



You should then be presented with a large number of log entries. You may see many events with the Event ID 4624 - Logon events. 4624 is the code that means an account has successfully logged on.

4. What does Event ID 4672 mean? What privileges are assigned to somebody who logs in under this action? Be specific, no less than five sentences.

## Group Policies

Group Policies are a means to customize the behavior of the Windows operating system, both in standalone machines and throughout entire domains. Policies can be used to set default auditing levels (logging verbosity), disable insecure security settings, and generally tailor the Windows environment to meet the needs of the corporate environment security policies. Windows Active Directory is a common system for managing multi-machine Windows networks and is typically used for centralized authentication and policy management (among other things).

## Disabling NTLM

If you recall from lecture and the previous labs, the NTLM protocol for storing passwords in windows can lead to issues with security. We saw this with our Pass-The-Hash technique from Lab 04. We can be reminded of this via the picture below.

```
(root@kali)-[~]
# smbmap -u "Administrator" -p "cc01954a4137d5d78b0ea5a7df135b03:565c3996932701fed3c38e70b7e98768"
-H 79.61.216.108 -x "ipconfig"

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::5989:4093:b603:57b0%11
    IPv4 Address. . . . . : 79.61.216.108
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 79.61.216.254
```

An updated protocol, Kerberos, is a common replacement for networks utilizing a central login server, namely an Active Directory. However, in order to prevent the older NTLM protocol from being used, it must be manually disabled via the group policies (discussed above).

For this lab, we will not be deploying an Active Directory server. It would be a high amount of overhead for this lab and falls outside the course's scope. Instead, we will utilize the built-in Windows Policy Editor. The concept of using group policies in Active Directory is similar to what we will do with the Policy Editor on our local machine.

1. Open a new console on the machine X.X.X.108. Log into the Windows 10 box with the local Administrator account and password:: r0adTr1p (zero and one).
2. Open the Policy editor by opening a CMD window (if you don't know how to do this, Google is a good resource) and executing the command `gpedit`.

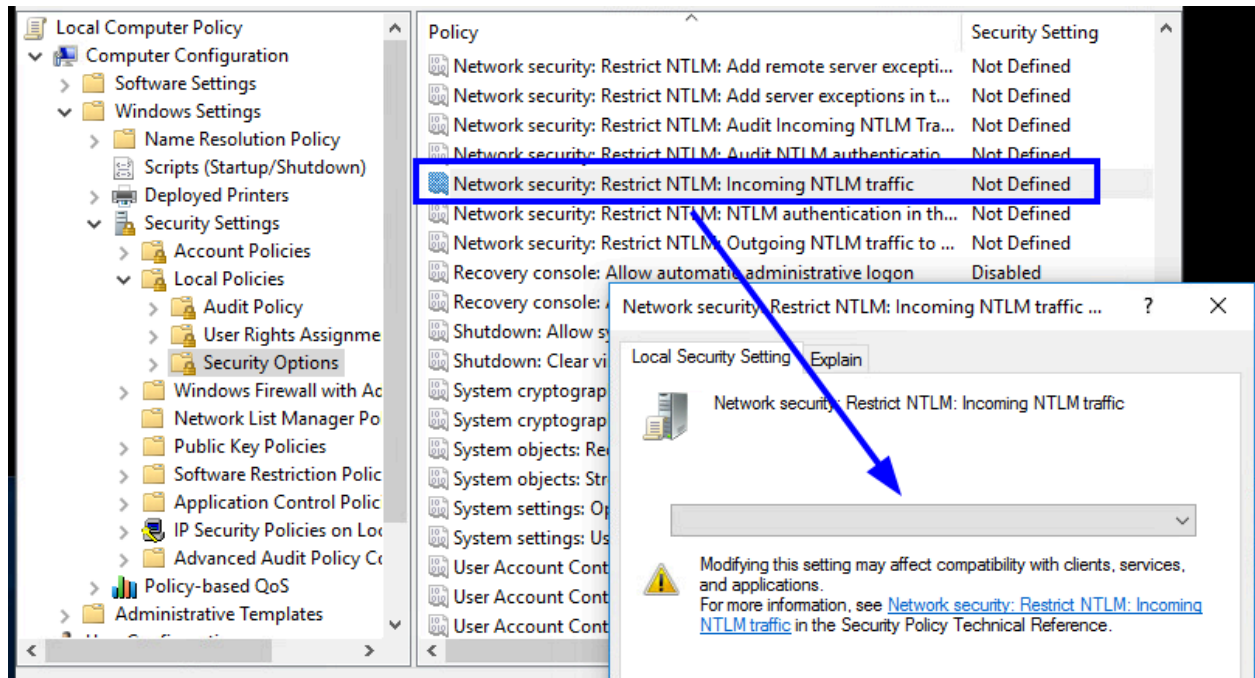
```
C:\ Command Prompt

Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

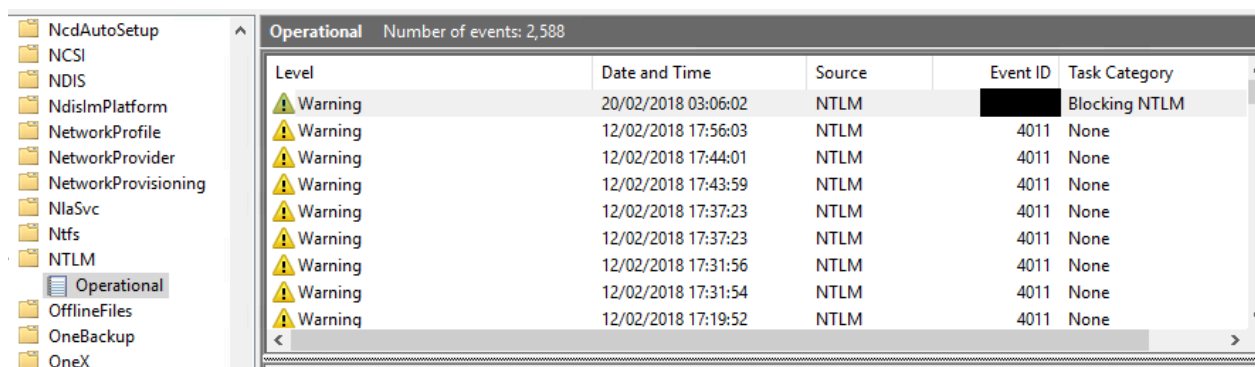
C:\Users\yellowsnow>gpedit
```

3. As you can see, the various policies are classified under various different categories. We will be working primarily under the “Computer Configuration->Windows Settings->Security Settings->Local Policies” group. Navigate to that subdirectory, and click on the “Security Options” category.

To disable NTLM login, Scroll down and find the entry named “Network security: Restrict NTLM: Incoming NTLM traffic”, double click on its row, and set the property to “Deny all accounts”. When prompted, confirm that you do want to make the change.



4. The change should take effect immediately. To verify that NTLM is now blocked, attempt to exploit the machine with the psexec exploit you used from Lab 04 (AKA, Pass the Hash from Lab 04). **Take a screenshot of the failed Pass the Hash attempt in kali.**
5. The attempt to use NTLM to login should have been unsuccessful. By default, Windows is now configured to log blocked NTLM attempts. Reopen the Windows Event Viewer and navigate to "Applications and Services Logs -> Microsoft -> Windows -> NTLM -> Operational". Open the most recent entry, which should be "Blocking NTLM"
6. **Take a screenshot of the failed NTLM login in Windows Event Viewer. What is the Event ID (four-digit code) of the failed login?**



## Password Policies

Another policy that is of interest is the Password Policy. This mechanism allows restrictions on password age, reuse, and difficulty to be set and enforced.

Within the Policy Editor, find the Password Policy entry and make the following changes:

1. Enforce password history: **5**
2. Max password age: **32 days**
3. Passwords must meet complexity requirements: **Enabled**.

**Take a screenshot of the changed password policies and include in your submission.**

| Policy                                                                                                                        | Security Setting       |
|-------------------------------------------------------------------------------------------------------------------------------|------------------------|
|  Enforce password history                    | 0 passwords remembered |
|  Maximum password age                        | 42 days                |
|  Minimum password age                        | 0 days                 |
|  Minimum password length                     | 0 characters           |
|  Password must meet complexity requirements  | Disabled               |
|  Store passwords using reversible encryption | Disabled               |

**What are the requirements that must be met when “complexity requirements” is enabled?** Hint: The policy should “Explain” what these requirements are. Do not copy and paste this information into your lab report. Summarize using your own words.

## Firewall

The de-facto method to limit access to network resources is through the use of a firewall. As we have discussed in CprE 2300, ports are the communication endpoints through which applications on a server communicate with other applications or processes. These processes can be on the same machine (MySQL databases and local processes) or on opposite sides of the Internet (websites and web browsers). Naturally, ports that are only needed locally should not be exposed to the Internet. In a similar fashion, some services are insecure by default and can only be operated in secure/trusted network settings (telnet within LANs, and even then it is a really, really bad idea) - thus the need for firewalls to govern network traffic.

A firewall is a mechanism that actively allows or denies connections based upon predetermined rules or expected stateful behavior. Two types of firewalls exist: host-based firewalls and network-based firewalls. Host-based run on the same machine which hosts the services to be secured, while network firewalls “filter” traffic as it enters or leaves a network. A common practice for both host-based and network-based firewalls is to block all incoming connections on the public interface by default and provide special exceptions for ports that should allow external access.

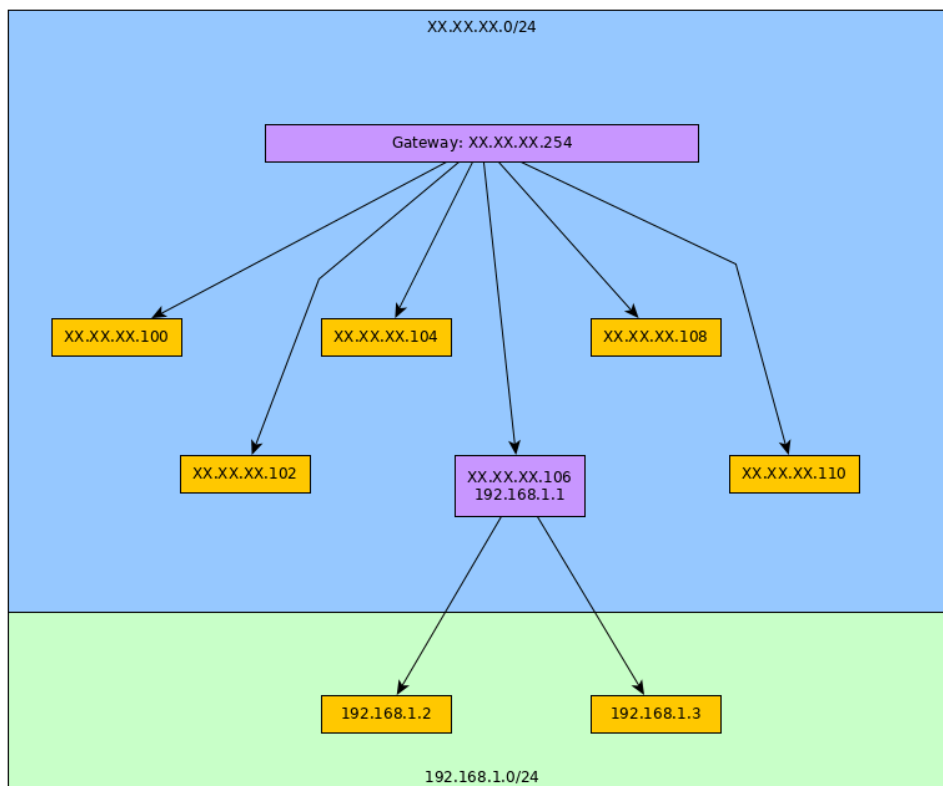
Network firewalls help to segment networks into security domains, specifying which types of traffic are allowed to traverse specific regions of the network (think of the policies used to govern

access to a public-facing corporate website vs an internal intranet/document repository). Host-based firewalls help to prevent private services from being accessed externally - regardless of network firewall configuration.

## Network Firewall

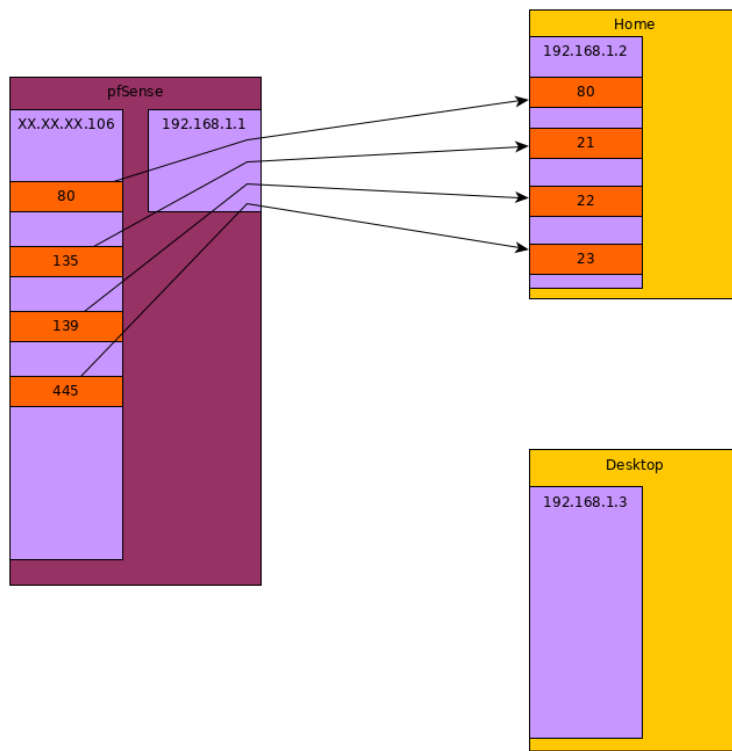
As you might have noticed in a previous lab, the `x.x.x.106` machine (Manny's Home server) is located behind a network-based firewall utilizing Network Address Translation (NAT). This explains two anomalies that you should have noticed in the past weeks.

1. The `x.x.x.106` address acts as a gateway to another network, `192.168.1.0/24`, which is why you connected to Home via the `x.x.x.106` box - yet running `ifconfig` showed that Home had an address of `192.168.1.2` (see the figure below).



2. The ports you noticed in Lab 02 (135, 139, and 445), while appearing to be ports associated with a Windows box, are being remapped to ports typically associated with Unix services (21, 22, 23) via special port-forwarding rules. We used the non-standard ports to demonstrate how the scan reports for a simple port scan just read from a list vs. a versioning scan results which interrogate the ports. It was to demonstrate the difference between the two types of scans. Additionally, as you can see in the image

below, port 80 is exposed externally and it is just forwarded to port 80 internally. There is no remapping done for that port.



As of now, `http`, `ftp`, `ssh`, and `telnet` services have port forwarding rules, allowing them to be accessed from the public internet, albeit some of the services are on non-standard ports (`ftp` on 135, `ssh` on 139, `telnet` on 445). While `http`, `ftp`, and `ssh` are standard services to offer to the public, `telnet` is an outdated and insecure protocol (which was succeeded by `ssh`). While `ssh` performs authentication over an encrypted channel either via challenge-response or RSA public/private key pairs, `telnet` operates entirely in plaintext and contains various other vulnerabilities (as an extra activity, you can verify this by capturing `telnet` traffic and searching through packets destined for port 445 to recover the plaintext password). Before we block access to the `telnet` port, we will first login and verify that it is running.

1. On your Kali machine, open a new terminal and log on to the Home server with `telnet` on port 445. Use Manny's username and password (**manny/LeaveMeAlone#**). Kali used to not come with `telnet` pre-installed. In that instance, we would update apt repo and install `telnet`. (`sudo apt update` then `sudo apt install telnet`). It may take a few minutes for `telnet` to connect to X.X.X.106.

```
(root@kali)~[~]
# telnet 23.143.140.106 445
Trying 23.143.140.106 ...
Connected to 23.143.140.106.
Escape character is '^]'.

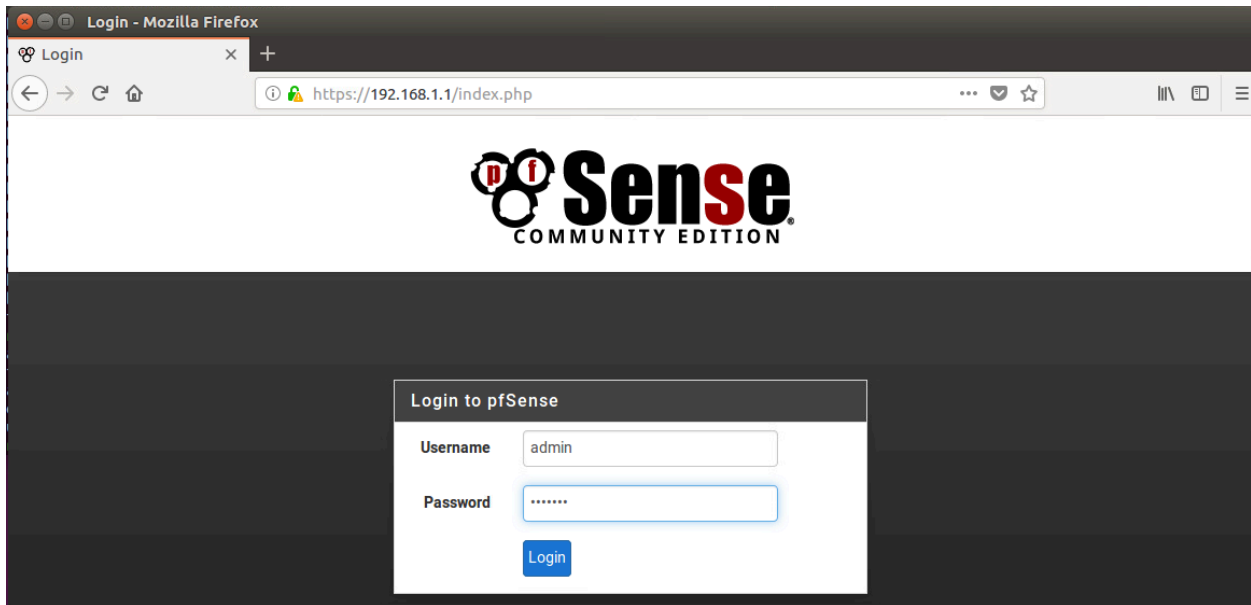
FreeBSD/i386 () (ttyp0)

login: manny
Password:
```

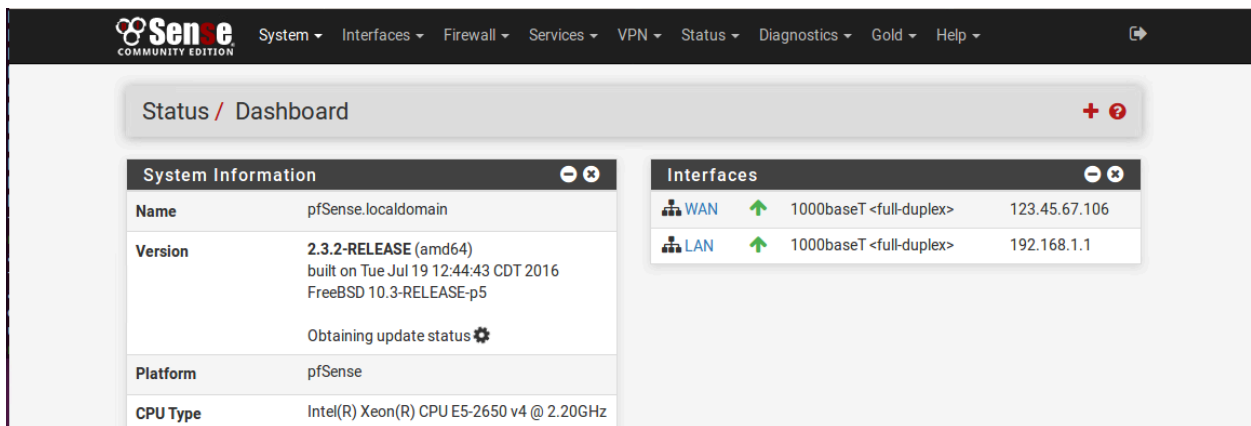
## 2. Take a screenshot showing the telnet command and successful login to X.X.X.106

The network firewall that we are using is pfSense, a standalone industry-standard firewall. To manage the firewall, it is necessary to use a web browser from the internal network segment. We have provided you with a new box named "PFDesktop" which is on the internal network at 192.168.1.3 with the username and password of **cpred310**.

- Log on to this machine and point Firefox at **192.168.1.1**. Log into the pfSense web administration interface with the username and password: **admin/pfsense**.



After logging in, you should be presented with a dashboard view of the current firewall stats and a menu bar of configurable settings.



4. Navigate to the Firewall->NAT settings page. On the column describing the 445-> 23 port mapping, click on the trashcan icon to delete the specified rule. When asked if the changes should be applied, click "Apply Changes".
5. **Take a screenshot of the new ruleset without the telnet port forwarding.**
6. To verify that the rule was successfully updated, attempt to connect to the X.X.X.106 host once more via Telnet. **Take a screenshot of the failed connection and include in your submission.**

## Host-based Firewall

To become familiar with host-based firewalls, we will deploy UFW (uncomplicated firewall) to better control which ports can be accessed from the public network.

1. Log onto the Ubuntu 12.10 box (called *ubuntuPing* in vSphere) with the username and password: **cpre2310/cpre2310**. This will provide you with a user granted with SuperUser permissions.
2. Examine which ports are open with the command: `netstat -nat`. This will show what ports are listening for incoming connections. Notice that along with ports 22, 80, and 443 (ssh/http/https), port 3306 is also open and listening for incoming connections. **Include a screenshot of the netstat -nat output in your lab submission.**
3. Using google, nmap, and/or lsof, determine what service typically runs on port 3306. **Include this in your lab submission.**
4. We want this service to be locally accessible for locally running services, yet prevent it from being accessed by external entities. UFW will help us to achieve this. Check the status of UFW with the command: `sudo ufw status`

```
cpre2310@ISEage:~$ sudo ufw status
[sudo] password for cpre2310:
Status: inactive
cpre2310@ISEage:~$ _
```

```
cpre2310@ISEage:~$ netstat -nat
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:443              0.0.0.0:*               LISTEN
tcp        0      0 0.0.0.0:3306             0.0.0.0:*               LISTEN
tcp6       0      0 :::22                   :::*                     LISTEN
cpre2310@ISEage:~$ _
```

5. Notice that it is inactive. Enable it with the command `sudo ufw enable`, and verify with the previous command that it was successfully started.

```
cpre2310@ISEage:~$ sudo ufw enable
Firewall is active and enabled on system startup
cpre2310@ISEage:~$ sudo ufw status
Status: active
cpre2310@ISEage:~$ _
```

6. Use the command `sudo ufw status verbose` to check what the default incoming and outgoing policies are set to - **Take a screenshot and include in your lab submission.**
7. Add rules for the ports: 22, 80, and 443 with the `sudo ufw allow <port>/tcp` command. This will create rules that allow the specified ports to be accessed externally via the tcp protocol.

```
cpre2310@ISEage:~$ sudo ufw allow 80/tcp
Rule added
Rule added (v6)
cpre2310@ISEage:~$ _
```

8. Verify that the desired rules were created by executing the `sudo ufw status` command once again. **Take a screenshot of the successfully created rules and include in your submission.**
9. Verify that port 3306 was successfully blocked by performing an nmap scan against the Ubuntu12.10 host. **Take a screenshot of the nmap scan results and include in your submission.**

## Patching

In Lab 03 to gain a root shell on the Ubuntu machine located at `x.x.x.104` via the Dirty Cow vulnerability. This was possible due to an outdated kernel which was susceptible to the aforementioned vulnerability. To run Lab 10 (this lab), we had to redeploy the ubuntuPing box to you so you will need to exploit it. This is easy to do by simply logging in as `scrat` (you have the password from Lab 03) and running the cow exploit.

1. First, log into the Ubuntu12.10 (ubuntuPing) box at `xx.xx.xx.104` via the vSphere console using `scrat` as the username (password from your lab notes).
2. From `/home/scrat` execute `./cow`. You should now have root access.

```

scrat@ISEage:~$ ./cow
DirtyCow root privilege escalation
Backing up /usr/bin/passwd to /tmp/bak
Size of binary: 42840
Racing, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd overwritten
Popping root shell.
Don't forget to restore /tmp/bak
root@ISEage:/home/scrat#

```

3. Log out from the scrat account by typing `exit, exit`

Because 12.10 is well past its end of life, you will be upgrading to 13.10 to fix the Dirty Cow vulnerability.

4. Log into the Ubuntu12.10 (ubuntuPing) box at `XX.XX.XX.104` via the vSphere console with the username and password: **cpre2310/cpre2310**.

Since Ubuntu 12.10 is EoL, we have to point the repositories to the old branches of Ubuntu. We have created a new `/etc/apt/sources.list` file for you to download from `repo.homework.2310.com`. We assume you are in `/home/cpre2310` when you run the `scp` command. When prompted for a password, use the password: **repo**.

5. `sudo scp repo@repo.homework.2310.com:new_sources.list .`

Change directory to `/etc/apt` and rename the existing sources list to `sources.list.orig`. Then copy the `new_sources.list` from `cpre2310`'s directory to `sources.list`. Then give it the appropriate permissions.

```

cd /etc/apt
sudo mv sources.list sources.list.orig
sudo cp /home/cpre2310/new_sources.list sources.list
sudo chmod 744 sources.list

```

6. You will have to set the proxy in `/etc/profile` and in the `sudoers` file before you can upgrade. Using `vi` or `nano` (again with `sudo`), **append the following lines** to the file `/etc/profile`.

```

export http_proxy="http://199.100.16.100:3128"
export https_proxy=$http_proxy
export ftp_proxy=$http_proxy

printf -v no_proxy '%s,' XX.XX.XX.{1..254}
export no_proxy="localhost,.2310.com,127.0.0.1,{no_proxy%},"

```

7. To allow these changes to take effect, run the following command from the terminal (or reboot your computer):  
`source /etc/profile`

By default, environment variables are ignored when running commands with `sudo`, for security reasons. This makes it difficult to run commands like `apt-get` (to update our machine) without being the root user. To configure `sudo` to keep the proxy settings, we must edit the `sudoers` file. To open up the `sudoers` file, use the following command:

8. `sudo visudo`
9. Add the following near the top of the file:  
`Defaults env_keep += "http_proxy https_proxy ftp_proxy no_proxy"`
10. Next, return to `cpre2310`'s home directory to create a new directory to contain the downloaded files, then `cd` into the new directory.  
`mkdir upgrade`  
`cd upgrade`
11. Run the following command to copy three deb files which contain kernel upgrade from the class repository. The fourth file contains the URLs from which the upgrade materials were downloaded. When prompted for a password, use the password: **repo**.  
`sudo scp repo@repo.homework.2310.com:~/upgrade/* .`

```
cpre2310@ISEage:~/upgrade$ sudo scp repo@repo.homework.2310.com:~/upgrade/* .
repo@repo.homework.2310.com's password:
linux-headers-3.16.45-031645_3.16.45-031645.2 100% 8867KB   8.7MB/s   00:01
linux-headers-3.16.45-031645-generic_3.16.45- 100% 671KB 671.4KB/s 00:00
linux-image-3.16.45-031645-generic_3.16.45-03 100% 51MB 51.5MB/s 00:01
urls.txt 100% 381 0.4KB/s 00:00
cpre2310@ISEage:~/upgrade$
```

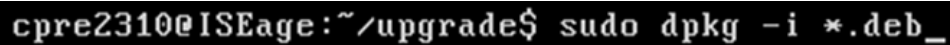
12. Open `urls.txt` with `less` (type the letter "q" to close it) and **specify in your report from which domain these packages are being downloaded from**. Why did we have to get the deb files from there?
13. After the secure copy completes, this should provide you with three `.deb` files. These are special package files containing the desired 3.16.45 kernel. Install all three of these files with the following command:  
`sudo dpkg -i *.deb`

14. Reboot the machine `sudo reboot`.

15. There are four additional steps to upgrade to Ubuntu 13.10. These will take a while and may require you to press 'y' to continue several times. You may be prompted about the grub configuration. Use the maintainer's version. You may also be told you are upgrading to saucy. Accept those changes with a 'y'.

```
sudo apt-get update
sudo apt-get upgrade
sudo apt-get dist-upgrade
sudo do-release-upgrade
```

16. After the install has successfully completed, you will be prompted to reboot the machine. After the machine has rebooted, login as the cpre2310 user (**cpre2310/cpre2310**) and **take a screenshot of the new kernel version (uname -a).**



```
cpre2310@ISEage:~/upgrade$ sudo dpkg -i *.deb_
```

17. Log out of cpre2310 and log in as scrat (you have his password from lab 03). Attempt to run the Dirty Cow exploit again. *The program should hang*, printing "Thread stopped" to the screen, indicating it was not able to successfully overwrite the passwd utility with the MSVenom shellcode. **Take a screenshot of this and include in your submission.**

18. As you can see, it is very cumbersome to upgrade once your OS has reached EoL. Identify each version (not point releases, but actual versions) will you have to upgrade through to get from 13.10 to the current LTS (long-term support) version of the server? Remember, the releases in April (X.4) are the LTS versions. **Include in your submission.**

## Turn In

1. **Submit a screenshot of the SSH brute force you performed from Lab 04.**  
(5 points)
2. **Take a moment and list three potential services/options that could be configured to help mitigate brute-force attacks and why**  
(5 points)
3. **Explain two additional methods we can use to prevent brute force attacks. Be specific.**  
(5 points)

- 4. What does Event ID 4672 mean? What privileges are assigned to somebody who logs in under this action? Be specific, no less than five sentences.**  
(5 points)
- 5. Screenshot of the failed Pass the Hash attempt in kali.**  
(5 points)
- 6. Take a screenshot of the failed NTLM login in Windows Event Viewer. What is the Event ID (four-digit code) of the failed login?**  
(5 points)
- 7. Screenshot of modified password policy**  
(5 points)
- 8. What are the “complexity requirements” that we have enforced?**  
(5 points)
- 9. Screenshot of successful telnet login**  
(5 points)
- 10. Screenshot of updated pfSense port-forwarding rules**  
(5 points)
- 11. Screenshot of failed telnet login**  
(5 points)
- 12. Screenshot of listening ports on XX.XX.XX.104**  
(5 points)
- 13. What service is running at port 3306?**  
(5 points)
- 14. Screenshot of default incoming/outgoing UFW policies**  
(5 points)
- 15. Screenshot of newly created UFW rules**  
(5 points)
- 16. Screenshot of nmap scan results showing blocked port 3306**  
(5 points)
- 17. Specify which domain these packages are being downloaded from. Why?**  
(5 points)

**18. Screenshot of upgraded kernel version**

(5 points)

**19. Screenshot of “hung” Dirty Cow**

(5 points)

**20. Identify each version you would have to upgrade through to get from 13.10 to the current LTS**

(5 points)